ZERO TRUST NETWORK ACCESS (ZTNA) WITH ZSCALER: SECURING USER-TO-APPLICATION CONNECTIVITY

Project details

Title: Zero Trust Network Access (ZTNA) with Zscaler: Securing User-to-Application Connectivity

• AI-Enhanced User Protection (AIUP)

AI-Enhanced User Protection (AIUP) is a modern security system that uses artificial intelligence (AI) and machine learning to check user identity and protect online platforms from cyber attacks. Unlike traditional security methods that depend only on passwords or two-factor authentication (2FA), AIUP continuously studies the behavior of users and creates a changing "trust score" for each user.

AIUP is important for today's online security because it solves the problems of old security systems that protect only the network boundary. Cyber threats are becoming more advanced, and attackers now use stolen passwords, phishing attacks, and social engineering techniques. Because of this, depending only on "what you know" (like passwords) or "what you have" (like security tokens) is not enough. AIUP adds another important layer called "who you are", which is identified through user behavior. This helps organizations stop account hacking, reduce fraud, and make sure that the person using the platform is really the correct user during the whole session.

Abstract:

Traditional VPN systems have many limitations in protecting modern networks. They often give users too much network access, which can allow attackers to move easily inside the network if they gain access. Because of this, organizations need a new security approach called Zero Trust.

This project explains the design, setup, and management of a Zero Trust Network Access (ZTNA) solution using Zscaler Zscaler Private Access (ZPA) in a large institutional network. The main goal of the project is to replace full network access with application-specific access based on user identity.

In this system, Zscaler App Connectors are deployed in the data center and connected with existing identity services like Microsoft Azure Active Directory and endpoint security tools. All connections between users and applications pass through a cloud-based security broker, which verifies the user before giving access.

This method makes internal applications invisible to the internet, which removes many possible attack points. The project also studies the integration of Zscaler with other security systems such as IBM QRadar for centralized logging and Malware Information Sharing Platform for threat intelligence. These integrations help create adaptive access policies based on security information.

As a result, the system provides a strong and scalable security framework that allows only the required level of access, maintains detailed security logs, and greatly improves the organization's protection against cyber threats.

Use Case Scenarios

Scenario 1: Secure Remote Access for Faculty to ERP System

A faculty member working from home needs to access the university ERP system to upload student grades. Using Zscaler Private Access, the faculty member connects securely without joining the internal network. The system checks the user's identity through Microsoft Azure Active Directory Multi-Factor Authentication (MFA) and also verifies whether the device is secure before allowing access.

Output:

- Faculty user identity is verified (Faculty_Group)
- Device security is checked (antivirus active and operating system updated)
- A secure connection is created only to the ERP application
- The internal network is completely hidden from the user

Scenario 2: External Researcher Accessing a Specific Database

A researcher from another institution needs temporary access to a research database stored on Vellore Institute of Technology servers. The administrator creates a special policy in Zscaler Private Access that allows access only for a limited time and only to that specific database. The researcher cannot see or access any other part of the university network.

Output:

- External researcher identity verified using temporary credentials
- Access allowed only for 7 days and only to the Research Database
- Database server remains hidden from internet scans
- User session automatically ends after the policy expires

Scenario 3: Student Access to Online Examination Portal

During final exams, many students access the internal online exam portal from different locations. Zscaler Private Access ensures that only authenticated students with secure devices can access the exam server. It also protects the login page from attacks and prevents users from reaching other internal systems.

Output:

- Cloud system manages authentication for thousands of students
- Each student connects only to the exam application

- Access to other systems like grade databases is blocked
- The exam server IP address stays hidden from the internet

Scenario 4: IT Administrator Performing Server Maintenance

An IT administrator needs to update an internal application server. Instead of using a VPN with full network access, the administrator connects through Zscaler Private Access directly to the server's management interface. The session is monitored, and if the administrator tries to access any unauthorized server, the system automatically stops the session.

Output:

- Administrator identity verified using MFA
- Secure connection created only to the server management interface
- All commands and keystrokes recorded for auditing
- Any attempt to access another server is automatically blocked

Scenario 5: Temporary Contractor Access During System Upgrade

During a university system upgrade, a contractor needs temporary access to a file server to move data. Using Zscaler Private Access, the contractor receives access only to the required file server. They are not added to the university's main user directory or given VPN access. After the project ends, the access is automatically removed.

Output:

- Contractor identity verified using a separate identity system
- Access allowed only to the File-Server-Migration folder
- All file transfer activities recorded in IBM QRadar and Zscaler logs
- Access automatically removed after the 30-day project period

STAGE 1

Title of the Project:

Implement and Manage Zero Trust Network Access (ZTNA) using Zscaler

Overview

Zero Trust Network Access (ZTNA) is a modern cybersecurity model that focuses on protecting organizational networks and applications by following the principle "Never Trust, Always Verify." Traditional network security models rely on perimeter-based protection mechanisms such as firewalls and Virtual Private Networks (VPNs). In these traditional systems, once a user is authenticated and allowed inside the network, they are often granted wide access to internal systems and resources. This approach creates security risks because if an attacker compromises a single account or device, they may gain access to multiple resources within the network.

With the rapid growth of cloud computing, remote working environments, mobile devices, and distributed enterprise applications, traditional network security models are no longer sufficient. Organizations require more secure and flexible methods to control access to applications and data. Zero Trust Network Access addresses these challenges by ensuring that every user, device, and application request is verified before granting access.

In a Zero Trust architecture, trust is never assumed based on network location. Every request is evaluated based on several security factors including user identity, device health, location, and security policy compliance. This ensures that only authorized users can access specific applications and resources.

Zscaler is a cloud-based security platform that provides Zero Trust Network Access solutions. Zscaler enables organizations to securely connect users to applications without exposing the internal network to the public internet. Instead of allowing direct network access, Zscaler creates a secure connection between the user and the specific application they need. This reduces the attack surface and improves overall security.

One of the key advantages of Zscaler is its cloud-native architecture. Unlike traditional security appliances that require hardware installations, Zscaler operates entirely in the cloud. This allows organizations to scale their security infrastructure easily and support users from

any location. The platform also provides integrated security services such as threat protection, data loss prevention, and traffic inspection.

In this project, the primary objective is to analyze how Zero Trust Network Access can be implemented using Zscaler to enhance network security. The project also examines several vulnerabilities that commonly affect enterprise networks. These vulnerabilities can be exploited by attackers to gain unauthorized access, steal confidential information, or disrupt organizational operations.

By identifying these vulnerabilities and understanding their potential impact, organizations can implement appropriate security controls to mitigate risks. Zscaler's Zero Trust architecture helps organizations enforce strict access policies, verify user identities, monitor device security status, and continuously inspect network traffic for suspicious activity.

Another important aspect of this project is the analysis of how ZTNA improves security visibility and monitoring capabilities. Traditional networks often lack proper monitoring mechanisms, which allows attackers to remain undetected for long periods. With Zero Trust architecture, every access request is logged and monitored, enabling security teams to detect threats quickly.

The project also highlights the role of continuous authentication and authorization in preventing cyber attacks. Even after a user is authenticated, Zero Trust systems continuously evaluate the user's activity and access behavior. If suspicious activity is detected, access can be restricted or revoked immediately.

Furthermore, the project discusses how Zscaler helps protect sensitive data through encryption and secure communication channels. Data transmitted between users and applications is encrypted to prevent interception and unauthorized access. This ensures that confidential organizational information remains protected.

Another benefit of implementing Zero Trust Network Access is improved compliance with security regulations and standards. Many organizations must comply with regulations related to data privacy and cybersecurity. ZTNA solutions help organizations meet these requirements by enforcing strict security policies and maintaining detailed access logs.

Overall, this project demonstrates how implementing Zero Trust Network Access using Zscaler can significantly enhance enterprise network security. By eliminating implicit trust and enforcing strict verification mechanisms, organizations can reduce the risk of cyber attacks and protect critical business resources.

Objectives of the Project

The main objective of this project is to understand the concept of Zero Trust Network Access and its implementation using the Zscaler platform. The project also aims to analyse common network vulnerabilities and identify how Zero Trust architecture can mitigate these risks.

Another objective is to study the role of cloud-based security solutions in protecting modern enterprise networks. As organizations increasingly adopt cloud services and remote working models, traditional security solutions are no longer sufficient.

The project also aims to demonstrate how Zscaler provides secure access to applications without exposing the internal network infrastructure. By implementing Zero Trust principles, organizations can ensure that users are granted access only to the applications they need.

Additionally, the project analyzes various vulnerabilities such as weak authentication mechanisms, improper access control, unsecured VPN connections, and outdated software components. Understanding these vulnerabilities helps organizations develop effective strategies to improve their security posture.

Finally, the project aims to highlight the importance of continuous monitoring, identity verification, and strict policy enforcement in modern cybersecurity environments.

List of Teammates

S.no	Name	College	Contact
1	Naveena M	A.V.P College of Arts and Science	7904120816
2	Bhavitra B	A.V.P College of Arts and Science	8973767617
3	Bhavadharani G	A.V.P College of Arts and Science	8098117676
4	Brindha V	A.V.P College of Arts and Science	8056738510

List of Vulnerability Table

Sno	Vulnerability Name	CWE/CVE-No
1	Weak Authentication Mechanism	CWE-287
2	Improper Access Control	CWE-284
3	Unsecured VPN Access	CWE-319
4	Misconfigured Security Policies	CWE-16
5	Lack of Continuous Monitoring	CWE-778
6	Phishing Attacks	CWE-601
7	Unpatched Software Vulnerabilities	CWE-1104
8	Insufficient Device Security	CWE-693
9	Data Exposure in Transit	CWE-319
10	Lateral Movement in Network	CWE-284

REPORT

1) **Vulnerability Name**: Weak Authentication Mechanism

   CWE/CVE: CWE-287

   OWASP/SANS Category: Broken Authentication

Description: Weak authentication mechanisms are one of the most common vulnerabilities in modern enterprise networks. Many systems rely solely on passwords for user authentication. However, passwords can easily be compromised through techniques such as phishing attacks, brute force attacks, and credential theft. Attackers often use automated tools to guess weak passwords or exploit reused credentials across multiple systems.

When authentication systems are not properly secured, attackers can gain unauthorized access to sensitive applications and resources. Once attackers obtain valid login credentials, they can impersonate legitimate users and perform malicious activities without being detected. This can lead to serious security breaches and data theft.

The implementation of multi-factor authentication (MFA) significantly reduces the risk associated with weak authentication systems. MFA requires users to provide additional verification factors such as one-time passwords, biometric authentication, or security tokens.

Zero Trust Network Access systems such as Zscaler enforce strong authentication policies by integrating identity providers and multi-factor authentication mechanisms. This ensures that only verified users are granted access to enterprise applications.

Business Impact: Weak authentication mechanisms can lead to unauthorized access to critical business systems and confidential data. This may result in financial losses, reputational damage, and legal consequences for organizations.

2) Vulnerability Name: Improper Access Control

CWE/CVE: CWE 284

Description: Improper access control occurs when users are granted permissions that exceed their authorized roles or responsibilities. In many organizations, access permissions are not properly managed, allowing users to access sensitive data or administrative functions that they should not have access to.Attackers can exploit improper access control by escalating privileges or accessing restricted information. Once attackers gain access to sensitive systems, they may modify data, steal confidential information, or disrupt business operations.

Zero Trust architecture mitigates this vulnerability by implementing the principle of least privilege. Users are granted access only to the applications and resources required for their tasks. Continuous monitoring and policy enforcement ensure that unauthorized access attempts are blocked.

Business Impact: Improper access control may lead to unauthorized disclosure of confidential information and compromise the integrity of organizational systems.

3) Vulnerability Name: Unsecured VPN Access

CWE/CVE: CWE-319

OWASP/SANS Category: Sensitive Data Exposure

Description: Traditional Virtual Private Network (VPN) systems are commonly used by organizations to provide remote access to internal networks. While VPNs were once considered a secure solution, they have several limitations and vulnerabilities that can be exploited by attackers. In many organizations, once a user successfully authenticates through a VPN, they are granted broad access to internal network resources. This means that if an attacker compromises a user's credentials, they may gain unrestricted access to multiple systems within the organization.

Another issue with traditional VPN solutions is that they expose the internal network to external connections. Attackers may exploit VPN vulnerabilities or stolen credentials to gain entry into the network. Once inside, attackers can perform lateral movement, scanning internal systems for weaknesses and accessing sensitive data or applications.

Zero Trust Network Access solutions such as Zscaler eliminate the risks associated with traditional VPNs. Instead of allowing full network access, ZTNA connects users only to the specific applications they need. This approach prevents attackers from exploring the internal network even if credentials are compromised.

Furthermore, Zscaler creates secure outbound connections from applications to the cloud platform, ensuring that internal applications remain hidden from the public internet. By eliminating inbound connections and restricting access to specific resources, organizations can significantly reduce the risk of cyber attacks.

Business Impact: Unsecured VPN access can allow attackers to gain unauthorized entry into the organization's internal network. This can lead to data breaches, disruption of services, and financial losses.

4) Vulnerability Name: Misconfigured Security Policies

CWE/CVE: CWE-16

OWASP/SANS Category: Security Misconfiguration

Description: Security misconfiguration is one of the most common vulnerabilities in enterprise environments. It occurs when systems, applications, or security devices are not configured properly. This may include default passwords, open ports, unnecessary services, or weak security policies. Attackers often scan networks to identify systems that are misconfigured and exploit them to gain unauthorized access.

In many organizations, security configurations are not regularly reviewed or updated. As a result, outdated settings may remain in place even after new threats emerge. Misconfigured access control policies may also allow unauthorized users to access sensitive systems or data.

Zero Trust architecture helps reduce the risk of security misconfiguration by enforcing centralized security policies. With Zscaler, administrators can define strict access rules that control which users can access specific applications. These policies are continuously enforced and monitored through the cloud platform.

Another advantage of centralized policy management is improved visibility. Security teams can easily review configurations and identify potential misconfigurations before they are exploited by attackers.

Business Impact: Security misconfigurations may allow attackers to bypass security controls and gain unauthorized access to sensitive information. This can result in data breaches, service outages, and compliance violations.

5)Vulnerability Name: Lack of Continuous Monitoring

CWE/CVE: CWE-778

OWASP/SANS Category: Insufficient Logging and Monitoring

Description: Continuous monitoring is an essential component of modern cybersecurity strategies. Without proper monitoring systems, organizations may fail to detect suspicious activities or cyber attacks. Many attackers rely on stealth techniques that allow them to remain undetected for long periods while they gather information or move across the network.

When organizations do not monitor user activities, login attempts, and network traffic, they may not notice unusual behavior such as unauthorized access attempts or abnormal data transfers. This lack of visibility can significantly delay the detection of security incidents.

Zero Trust solutions such as Zscaler provide continuous monitoring and logging capabilities. Every access request and user activity is recorded and analyzed in real time. Security teams can review logs to identify patterns of suspicious behavior and respond quickly to potential threats.

Advanced monitoring systems can also use artificial intelligence and behavioral analysis to detect anomalies. For example, if a user suddenly attempts to access systems from an unusual location or device, the system can flag this activity as suspicious.

Business Impact: Without proper monitoring, attackers may remain undetected within the network and cause significant damage. This may lead to data theft, financial loss, and reputational damage.

6)Vulnerability Name: Phishing Attacks

CWE/CVE: CWE-601

OWASP/SANS Category: Identification and Authentication Failures

Description: Phishing attacks are one of the most common methods used by cybercriminals to steal user credentials and sensitive information. In a phishing attack, attackers create fake emails, websites, or messages that appear to come from legitimate sources. These messages trick users into entering their login credentials or downloading malicious software.

Once attackers obtain valid credentials, they can use them to access enterprise systems and perform unauthorized activities. Phishing attacks are particularly dangerous because they target human behaviour rather than technical vulnerabilities.

Zero Trust security frameworks help mitigate phishing risks by requiring multiple verification steps before granting access to applications. Even if attackers obtain a user's password, they cannot access systems without passing additional authentication checks.

Zscaler also provides security features such as secure web gateways and phishing detection systems that block malicious websites and suspicious links before users interact with them.

Business Impact: Successful phishing attacks can lead to compromised accounts, unauthorized transactions, and data breaches. Organizations may suffer financial losses and damage to their reputation.

7) Vulnerability Name: Unpatched Software Vulnerabilities

CWE/CVE: CWE-1104

OWASP/SANS Category: Vulnerable and Outdated Components

Description: Software vulnerabilities are weaknesses in applications or operating systems that attackers can exploit to gain unauthorized access. Software vendors regularly release updates and security patches to fix these vulnerabilities. However, many organizations fail to apply these updates promptly.

Outdated software systems are attractive targets for attackers because their vulnerabilities are publicly documented. Attackers can easily exploit these weaknesses using automated tools.

Zero Trust security models help reduce the risk associated with unpatched systems by limiting network access and isolating vulnerable applications. Even if a vulnerability exists, attackers cannot easily access the affected system without passing strict security checks.

Organizations should also implement regular patch management processes to ensure that all systems are updated with the latest security fixes.

Business Impact

Unpatched software vulnerabilities can lead to system compromise, malware infections, and data breaches.

8)**Vulnerability Name**: Insufficient Device Security

CWE/CVE:CWE-693

OWASP/SANS Category: Security Misconfiguration

Description: In many organizations, employees use personal devices such as laptops, smartphones, and tablets to access enterprise systems. If these devices are not properly secured, they may introduce security risks into the network.

Devices that lack antivirus protection, encryption, or operating system updates may become infected with malware. Attackers can use compromised devices to access enterprise applications or steal sensitive information.

Zero Trust systems evaluate the security posture of devices before allowing access to applications. This process is known as device posture verification. If a device does not meet security requirements, access may be restricted or denied.

Zscaler integrates with device management systems to ensure that only secure and compliant devices can access enterprise resources.

Business Impact: Insecure devices can act as entry points for cyber attacks, leading to data loss and system compromise.

9) Vulnerability Name: Data Exposure in Transit

CWE/CVE:CWE-319

OWASP/SANS Category: Sensitive Data Exposure

Description: Data transmitted across networks may be intercepted by attackers if it is not properly encrypted. Attackers can use techniques such as man-in-the-middle attacks to capture sensitive information during transmission.

This vulnerability is particularly dangerous when users access applications over public networks such as Wi-Fi hotspots. Without encryption, login credentials, financial information, and confidential documents may be exposed.

Zero Trust solutions ensure that all communication between users and applications is encrypted using secure protocols. Zscaler provides secure tunnels that protect data during transmission.

By encrypting network traffic and verifying connections, organizations can prevent attackers from intercepting sensitive information.

Business Impact: Data exposure during transmission can lead to identity theft, financial fraud, and loss of confidential business information.

10)Vulnerability Name: Lateral Movement in Network

CWE/CVE: CWE-284

OWASP/SANS Category: Broken Access Control

Description: Lateral movement refers to the technique used by attackers to move from one compromised system to other systems within a network. After gaining initial access, attackers attempt to explore the network and identify valuable targets such as databases, servers, and administrative accounts.

Traditional network architectures often allow unrestricted communication between internal systems. This makes it easier for attackers to move laterally without detection.

Zero Trust architecture prevents lateral movement by isolating applications and enforcing strict access policies. Users are granted access only to specific applications, not to the entire network.Zscaler also hides internal applications from public networks, reducing the chances that attackers can discover them.

Business Impact: Lateral movement allows attackers to escalate their attacks and access critical systems. This can result in large-scale data breaches and operational disruptions.

Stage 2

Overview :

Zero Trust Network Access (ZTNA) is a modern security model that replaces traditional VPN-based access by ensuring that **users and devices are never trusted by default**, regardless of whether they are inside or outside the corporate network. Instead, access to applications is granted based on **verified identity, device posture, and contextual security policies**.

In this approach, organizations implement ZTNA using **Zscaler**, a cloud-based security platform that enables **secure, identity-driven connectivity between users and applications**. Rather than exposing internal applications to the internet or providing full network access through VPNs, Zscaler connects users directly to specific applications through a **brokered, policy-controlled connection**.

By deploying Zscaler's ZTNA capabilities (commonly through **Zscaler Private Access**), organizations can ensure that internal applications remain **hidden from public networks**, significantly reducing the attack surface. Access is granted only after verifying user identity through enterprise identity providers and enforcing security policies such as **multi-factor authentication, device compliance, and least-privilege access**.

This model improves both **security and user experience** by eliminating the need for traditional VPN tunnels, enabling faster, scalable, and cloud-delivered access to private applications from any location. Administrators can centrally manage policies, monitor access activity, and ensure continuous verification of users and devices.

Overall, implementing ZTNA with Zscaler allows organizations to **securely connect users to applications rather than networks**, aligning with modern **Zero Trust architecture principles** while supporting remote work, cloud adoption, and hybrid environments.

Target website: https://ginandjuice.shop/

Target IP address: 34.246.169.176

List of vulnerability :

s.no	Vulnerability name	Severity	plugins
1	HSTS Missing from HTTPS server (RFC 6797)	MEDIUM	142960
2	SSL Certificate information	INFO	10863
3	SSL/TALS versions supporter	INFO	56984
4	TLS ALPN supported protocol enumeration	INFO	84821
5	Web server crafted request vendor/version information disclosure	INFO	11239

6	Service detection	INFO	22964
7	Nessus SYN scanner	INFO	11219
8	Additional DNS host names	INFO	46180
9	Nessus scan information	INFO	19506
10	OS Fingerprint detected	INFO	209654

REPORT

1. **Vulnerability Name:** HSTS Missing from HTTPS server (RFC 6797)

Severity : MEDIUM

Plugin: 142960

Port : 443

Description: The remote web server is not enforcing HSTS, as defined by RFC 6797. HSTS is an optional response header that can be configured on the server to instruct the browser to only communicate via HTTPS. The lack of HSTS allows downgrade attacks, SSL-stripping man-in-the-middle attacks, and weakens cookie-hijacking protections.

Solution: Configure the remote web server to use HSTS.

Business Impact: The vulnerability HTTP Strict Transport Security (HSTS) Missing from HTTPS Server refers to the absence of a security policy that forces browsers to always use secure HTTPS connections when communicating with a web server. HSTS is defined in RFC 6797 and helps protect users from protocol downgrade attacks and cookie hijacking.

The absence of HTTP Strict Transport Security (HSTS) as defined in RFC 6797 allows attackers to downgrade secure HTTPS connections to HTTP. This increases the risk of man-in-the-middle attacks, session hijacking, and data interception. As a result, organizations may face data breaches, loss of customer trust, compliance issues, and potential financial or reputational damage.

2. **Vulnerability Name:** SSL Certificate information in short

Severity : INFO

Plugin: 10863

Port : 443

Description: This plugin connects to every SSL-related port and attempts to extract and dump the X.509 certificate.

solution: -

Business Impact: Exposure of **SSL Certificate** information can reveal important details about an organization's web infrastructure, including domain names and certificate configuration. Attackers may use this information for reconnaissance to better understand the system environment. It may also expose subdomains or internal server details, which increases the attack surface. With this information, threat actors can plan targeted cyberattacks or create phishing websites that appear legitimate. This can increase the risk of unauthorized access attempts against web applications.

Poor certificate visibility may also indicate weak security management practices within the organization. If such issues are identified during security scans or audits, it may negatively affect the organization's security posture. Customers and partners may lose trust if security weaknesses are publicly known. Organizations could also face compliance concerns with standards such as **PCI DSS** and **ISO/IEC 27001**. Overall, this vulnerability can contribute to increased cybersecurity risks and potential reputational damage.

3. Vulnerability Name: SSL/TALS versions supporter
severity : INFO

Plugin:56984

Port :443

Description: This plugin detects which SSL and TLS versions are supported by the remote service for encrypting communications.

solution: -

Business Impact: Supporting outdated versions of **Secure Sockets Layer (SSL)** or older **Transport Layer Security (TLS)** can expose an organization to known security vulnerabilities. Attackers may exploit weaknesses in these older protocols to intercept or manipulate encrypted communications. This increases the risk of **man-in-the-middle attacks** where sensitive data such as login credentials or personal information can be captured. As a result, confidential business and customer data may be compromised.

The presence of outdated protocols also indicates weak security configurations in the system. This may negatively impact the organization's **security posture and customer trust**. It can also lead to **compliance issues** with security standards such as **PCI DSS** and **ISO/IEC 27001**. Overall, this vulnerability can increase the risk of cyberattacks, reputational damage, and financial loss.

4. Vulnerability Name: TLS ALPN supported protocol enumeration

severity : INFO

Plugin: 84821

Port :443

Description: The remote host supports the TLS ALPN extension. This plugin enumerates the protocols the extension supports.

solution: -

Business Impact: The vulnerability **TLS ALPN Supported Protocol Enumeration** occurs when a server reveals the list of protocols it supports through **Application-Layer Protocol Negotiation (ALPN)** during the **Transport Layer Security (TLS)** handshake. This information can help attackers understand the server's configuration and supported communication protocols. Such exposure can assist in **reconnaissance and targeted attack planning** against the system.

It may also reveal outdated or insecure protocols that attackers could exploit. As a result, it increases the organization's **attack surface and security risk**. If misused, this information could

contribute to **unauthorized access attempts or service exploitation**. Additionally, repeated findings in security scans may affect the organization's **security posture and compliance standing**. Overall, it can lead to increased risk of cyberattacks and potential reputational impact.

5. Vulnerability Name: Web server crafted request vendor/version information disclosure

severity : INFO

Plugin: 11239

Port :443

Description: The web server running on the remote host appears to be hiding its version or name, which is a good thing. However, using a specially crafted request, Nessus was able to discover the information.

Solution: No generic solution is known. Contact your vendor for a fix or a workaround.

Business Impact: The vulnerability Web Server Crafted Request Vendor/Version Information Disclosure occurs when a server reveals its software vendor or version details in response to specially crafted requests. This may expose information about the underlying web server software, such as Apache HTTP Server, Nginx, or Microsoft Internet Information Services.

Attackers can use this information for **reconnaissance** to identify known vulnerabilities associated with that specific version. This increases the risk of **targeted attacks and exploitation attempts**. If successfully exploited, it could lead to unauthorized access or service disruption. The exposure also indicates weak security configuration practices. Repeated findings in security scans may negatively affect the organization's **security posture and compliance status**. Overall, it increases the likelihood of cyberattacks and potential reputational impact.

6. Vulnerability Name: Service detection

Severity : INFO

Plugin:22964

Port :443

Description: Nessus was able to identify the remote service by its banner or by looking at the error message it sends when it receives an HTTP request.

Solution: -

Business Impact: The **Service Detection** vulnerability occurs when a system reveals information about the services running on a server, such as web, database, or remote access services. This allows attackers to identify the technologies and applications used within the infrastructure. With this information, attackers can perform **reconnaissance** and search for known vulnerabilities in those services.

It increases the organization's **attack surface** and the likelihood of targeted cyberattacks. If exploited, attackers may attempt unauthorized access or service exploitation. The exposure may also indicate weak security configurations. Repeated findings in security assessments can negatively affect the organization's **security posture and compliance status**. Overall, this vulnerability increases the risk of targeted attacks and potential operational disruption.

7. Vulnerability Name : Nessus SYN scanner

Severity : INFO

Plugin:11219

Port :443

Description: This plugin is a SYN 'half-open' port scanner. It shall be reasonably quick even against a firewalled target.

Note that SYN scans are less intrusive than TCP (full connect) scans against broken services, but they might cause problems for less robust firewalls and also leave unclosed connections on the remote target, if the network is loaded.

solution: Protect your target with an IP filter.

Business Impact: The **Nessus SYN Scanner** finding indicates that systems can be discovered through **SYN Scan** techniques, which identify open ports and active services on a network. If attackers perform similar scans, they can map the organization's network and identify exposed systems. This information helps them locate potential entry points for exploitation.

Open or poorly secured ports may allow unauthorized access or targeted attacks. It also increases the organization's **attack surface** and overall security risk. Such findings may indicate weak network monitoring or filtering controls. If left unaddressed, attackers may use the discovered information to plan further cyberattacks. Overall, it can lead to increased risk of intrusion, service disruption, and reputational damage.

8. Vulnerability Name: Additional DNS host names

severity :INFO

Plugin:46180

Port :443

Description: Hostnames different from the current hostname have been collected by miscellaneous plugins. Nessus has generated a list of hostnames that point to the remote host. Note that these are only the alternate hostnames for vhosts discovered on a web server.

Different web servers may be hosted on name-based virtual hosts.

solution: If you want to test them, re-scan using the special vhost syntax, such as :

www.example.com[192.0.32.10]

Business Impact: The **Additional DNS Host Names** vulnerability occurs when extra domain names or subdomains are publicly discoverable through **Domain Name System (DNS)** records. This exposure can reveal internal or unused hostnames that are not meant to be publicly accessible. Attackers can use this information for **reconnaissance** to map the organization's infrastructure.

It may also help them identify hidden services or systems that could contain vulnerabilities. As a result, the organization's **attack surface increases**. These exposed hostnames may become targets for phishing, scanning, or exploitation attempts. It may also indicate poor DNS management or configuration practices. Overall, this vulnerability can lead to increased cybersecurity risks and potential reputational impact.

9. Vulnerability Name: Nessus scan information

severity : INFO

Plugin:19506

Port : N/A

Description: This plugin displays, for each tested host, information about the scan itself :

- The version of the plugin set.
- The type of scanner (Nessus or Nessus Home).
- The version of the Nessus Engine.
- The port scanner(s) used.
- The port range scanned.
- The ping round trip time
- Whether credentialed or third-party patch management checks are possible.
- Whether the display of superseded patches is enabled
- The date of the scan.
- The duration of the scan.
- The number of hosts scanned in parallel.
- The number of checks done in parallel.

solution: -

Business Impact: The **Nessus Scan Information** finding indicates that the system has been scanned and basic host or network information has been identified during the vulnerability assessment. While it is generally informational, it confirms that the host is **discoverable and reachable on the network**. Attackers performing similar scans can gather system details and identify potential vulnerabilities.

This information can be used for **reconnaissance and attack planning**. If security controls are weak, it may increase the likelihood of targeted exploitation. It may also highlight gaps in **network monitoring or intrusion detection**. Repeated findings can affect the organization's **security posture during audits**. Overall, it indicates potential exposure that could assist attackers in further cyberattack attempts.

10. Vulnerability Name: OS Fingerprint

Severity : INFO

Plugin:209654

Port : N/A

Description: Using a combination of remote probes (TCP/IP, SMB, HTTP, NTP, SNMP, etc), it was possible to gather one or more fingerprints from the remote system. While the highest-confidence result was reported in plugin 11936, "OS Identification", the complete set of fingerprints detected are reported here.

solution: -

Business Impact: The **OS Fingerprint** vulnerability occurs when a system reveals information about its operating system through network responses. Attackers can use this information to identify the specific OS running on the server, such as **Microsoft Windows** or **Linux**. This allows them to search for **known vulnerabilities** associated with that operating system.

With accurate OS details, attackers can plan **targeted exploitation attempts**. It increases the organization's **attack surface and security risk**. The exposure may also indicate weak network hardening or configuration practices. If exploited, it could lead to unauthorized access or system compromise. Overall, this vulnerability increases the risk of targeted cyberattacks and potential operational disruption.

STAGE 3

REPORT

Title:-Implementing Zero Trust Network Access (ZTNA) with Zscaler: Securing User-to-Application Connectivity

1. Zero Trust Network Access (ZTNA)

Zero Trust Network Access (ZTNA) is a modern cybersecurity approach designed to secure access to applications and services by eliminating the concept of inherent trust within a network. Traditional security models assume that users or devices inside a corporate network can be trusted, while external connections require verification. However, with the growth of cloud computing, remote work, and distributed applications, this perimeter-based security model has become inadequate. ZTNA follows the principle of "never trust, always verify," meaning every user, device, and connection must be authenticated and authorized before accessing any resource. The concept is strongly related to the broader cybersecurity philosophy of Zero Trust Security Model.

ZTNA works by creating a secure identity-based access layer between users and applications. Instead of allowing direct network access, the system grants access only to specific applications after verifying the user's identity, device posture, and context such as location or risk level. This approach significantly reduces the attack surface because applications remain hidden from the public internet and unauthorized users. Even if an attacker gains access credentials, additional verification steps such as multi-factor authentication and device compliance checks prevent unauthorized entry. As a result, ZTNA provides improved security compared to traditional Virtual Private Networks (VPNs), which often expose entire network segments once a user is authenticated.

Another key advantage of ZTNA is its ability to support modern work environments. Organizations today rely heavily on cloud-based services, remote employees, and mobile devices. ZTNA allows secure connections regardless of where the user is located, whether they are working from home, traveling, or using public networks. Because access decisions are based on identity and context rather than network location, organizations can maintain consistent security policies across all environments. Additionally, ZTNA systems provide detailed monitoring and logging of user activity, enabling security teams to detect suspicious behavior and respond quickly to potential threats.

From a business perspective, implementing ZTNA improves both security and operational efficiency. It reduces dependency on legacy infrastructure, simplifies access management, and provides a scalable framework for protecting modern digital assets. As cyber threats continue to evolve, many organizations are adopting ZTNA solutions as a core component of their cybersecurity strategy. By ensuring that every request is authenticated,

authorized, and continuously monitored, ZTNA creates a secure foundation for protecting sensitive applications and data in a dynamic digital environment.

2. Zscaler and Policy Enforcement – The Zscaler ZTNA Cycle

One of the leading platforms that enables ZTNA implementation is Zscaler. Zscaler provides a cloud-based security platform that connects users directly to applications while enforcing strict access policies. Instead of routing traffic through traditional data center security appliances, Zscaler operates through a distributed cloud network that securely connects users to applications based on identity and policy rules. This architecture improves performance, scalability, and security because traffic is inspected and controlled before reaching internal systems.

Zscaler enforces policies based on multiple contextual data points collected during the connection process. These data points include the user's identity, device security posture, geographic location, time of access, and application sensitivity. For example, a company may allow employees to access internal applications only from managed devices with updated security patches. If a user attempts to connect from an unknown device or suspicious location, the system may block access or require additional verification. This dynamic policy enforcement ensures that security decisions adapt to changing conditions, thereby reducing the risk of unauthorized access.

The Zscaler ZTNA cycle describes the process through which secure access is established and continuously maintained. The first stage involves user authentication, where the identity of the user is verified using identity providers such as enterprise authentication systems. Once identity verification is completed, the system evaluates the device posture, checking factors such as antivirus status, operating system updates, and device management compliance. These checks ensure that only trusted and secure devices can connect to corporate applications.

After authentication and device verification, the next stage involves policy evaluation. Zscaler analyzes the collected contextual information and determines whether the user should be granted access to the requested application. If the request satisfies the organization's security policies, Zscaler establishes a secure connection between the user and the specific application. Importantly, the user is connected only to the authorized application rather than the entire network, which prevents lateral movement within the system.

The final stage of the ZTNA cycle involves continuous monitoring and enforcement. Zscaler continuously analyzes user behavior, network traffic, and application activity to detect anomalies. If suspicious behavior is detected, the system can immediately revoke access, trigger alerts, or enforce additional security checks. This continuous verification ensures that trust is never permanent and that security remains active throughout the user session. By integrating authentication, policy enforcement, and continuous monitoring, Zscaler provides a comprehensive solution for implementing Zero Trust Network Access in modern organizations.

3. MISP (Malware Information Sharing Platform) Integration

Another critical component of a modern cybersecurity framework is threat intelligence sharing. The Malware Information Sharing Platform (MISP) is an open-source platform designed to facilitate the sharing, storing, and analysis of threat intelligence information among organizations. By integrating MISP with security solutions such as Zscaler, organizations can enhance their ability to detect and respond to emerging cyber threats in real time.

MISP enables organizations to collect and share information about malicious activities, including malware samples, suspicious IP addresses, domain names, phishing campaigns, and other indicators of compromise. Security teams can contribute intelligence data to the platform, which is then shared with other organizations within a trusted community. This collaborative approach improves overall cybersecurity by enabling organizations to learn from each other's experiences and respond more effectively to cyber threats.

When integrated with Zscaler, MISP can provide valuable threat intelligence that enhances policy enforcement. For example, if MISP identifies a newly discovered malicious domain associated with malware distribution, this information can be automatically fed into Zscaler's security policies. As a result, any attempt by users within the organization to access that domain can be immediately blocked. This integration ensures that the security system remains updated with the latest threat intelligence without requiring manual intervention.

Another advantage of integrating MISP with Zscaler is improved incident response. Security teams can analyze threat data collected from multiple sources and correlate it with network activity monitored by Zscaler. This correlation allows security analysts to identify patterns of suspicious behavior and take proactive measures to prevent attacks. For instance, if multiple organizations report similar phishing attempts through MISP, Zscaler can automatically update its filtering rules to prevent those phishing domains from reaching users.

The integration also supports automated threat detection and intelligence sharing workflows. Security operations teams can configure automated alerts, threat feeds, and response actions that trigger when specific indicators of compromise are detected. By combining the advanced threat intelligence capabilities of MISP with the cloud-based access control and monitoring provided by Zscaler, organizations can create a powerful defense system against modern cyber threats.

In conclusion, implementing Zero Trust Network Access using Zscaler and integrating it with threat intelligence platforms like MISP significantly strengthens organizational cybersecurity. ZTNA ensures that access to applications is strictly controlled based on identity and context, while Zscaler provides the cloud-based infrastructure to enforce these policies effectively. MISP enhances this system by supplying real-time threat intelligence that helps detect and block emerging threats. Together, these technologies create a comprehensive security framework that protects user-to-application connectivity while maintaining flexibility and scalability for modern digital environments.

College Network Infrastructure

A typical college network includes many devices and systems such as:

- Core routers
- Distribution switches
- Wireless access points
- Firewalls
- Intrusion Detection Systems
- Application servers

These servers host:

- Student information systems
- Library services
- Administrative portals
- Research databases

Currently, many colleges use **VPNs** to provide remote access.

However, VPNs have several problems.

Problems with VPN

1. Too much access – Users can access the entire network.
2. Risk of lateral movement – Attackers can move inside the network.
3. Poor user experience – VPN connections can be slow.
4. Security risks if a device is compromised.

Because of these issues, colleges need a better solution like ZTNA.

Deploying ZTNA Using Zscaler

To implement ZTNA using Zscaler in a college network, the following steps can be followed.

1. Application Discovery

Identify all internal applications such as:

- ERP systems
- Library servers
- Research databases

- File storage systems

2. User Segmentation

Divide users into groups such as:

- Students
- Faculty
- Administrative staff
- IT staff
- External researchers

Each group gets access only to specific applications.

3. Deploy App Connectors

Install Zscaler App Connector virtual machines in the college data center.

These connectors securely connect applications to the Zscaler cloud.

4. Identity Integration

Integrate Zscaler with the college identity provider such as Azure AD.

This allows users to log in using existing credentials.

5. Policy Configuration

Create access policies such as:

Faculty can access research servers after MFA verification.

Students can access library resources but not administrative systems.

6. Client Connector Installation

Install the Zscaler Client Connector on user devices.

This software automatically routes secure traffic to the Zscaler cloud.

Threat Intelligence

Threat intelligence helps security teams understand cyber threats.

It collects information from different sources such as:

- Zscaler cloud logs
- External threat feeds
- Identity provider logs

This information helps in detecting suspicious activities such as:

- Unusual login locations
- Access to unknown applications
- Communication with malicious websites

Threat intelligence improves security by enabling proactive protection.

Incident Response

Incident response is the process of detecting and responding to security attacks.

In a ZTNA environment, incident response becomes faster.

Step 1: Detection

The security team detects suspicious behavior such as unusual data downloads.

Step 2: Containment

The administrator can immediately block the user or device using the Zscaler dashboard.

Step 3: Eradication

The infected device is scanned and cleaned.

Step 4: Recovery

After fixing the issue, user access is restored.

Step 5: Review

Security teams analyze logs and update policies to prevent future attacks.

Advantages of ZTNA with Zscaler

Implementing ZTNA using Zscaler provides many benefits:

- Improved security
- Reduced attack surface
- Prevention of lateral movement
- Better user experience
- Scalable cloud architecture
- Detailed activity logs
- Faster incident response

Tools Used in This Project

Several cybersecurity tools were studied during this project.

These include:

- Nmap
- Metasploit
- Nessus
- Kali Linux
- OWASP ZAP
- Burp Suite

These tools help identify vulnerabilities, test security, and improve system protection.

Conclusion: -

In conclusion, exploring the realm of AI for web security using IBM QRadar has been an insightful journey through various stages.

Stage 1 understanding web application testing unveiled the critical importance of assessing vulnerabilities and ensuring the security of web-based systems. This foundational knowledge served as a cornerstone for comprehending the subsequent stages.

Stage 2 delved into the intricacies of Nessus reports, emphasising the significance of detailed vulnerability assessments. Analysing these reports provided valuable insights into potential threats, enabling informed decision-making for robust security measures.

Stage 3 introduced the pivotal concept of Zero Trust Network Access (ZTNA) and its implementation using Zscaler Private Access (ZPA). It demonstrated a paradigm shift from traditional VPN-based network access to secure, identity-based user-to-application connectivity. The solution showcased the power of hiding internal applications from the internet, enforcing granular access policies, and eliminating lateral movement. This underscores the need for modern, proactive cybersecurity strategies in an era of remote work and cloud adoption.

Considering the future scope

Stage 1 illuminated the evolving landscape of web application testing. With advancements in AI, there is a promising avenue for more sophisticated testing methodologies, ensuring even higher levels of security for web applications.

Stage 2 highlighted the future trajectory of the testing process, indicating a shift towards more automation and integration of AI-driven tools. This evolution promises quicker, more accurate vulnerability assessments, enhancing overall cybersecurity postures.

Stage 3 illuminated the future potential of Zero Trust Network Access (ZTNA) and Zscaler technologies. With AI integration and machine learning, these systems are poised to become more intelligent and adaptive, enabling real-time risk assessment based on user behavior and device posture. Enhanced automation in policy enforcement, predictive analytics for threat detection, and improved scalability are anticipated, empowering organizations to stay ahead of sophisticated cyber threats in an increasingly distributed world

In essence, the project not only provided a deep understanding of the current state zero trust using ZSCALER but also offered a glimpse into the exciting future of cybersecurity. Embracing these advancements will be crucial for organisations aiming to fortify their digital landscapes in the face of ever-evolving cyber threats.

Future Scope: -

Future of web application testing

The future of WAT is bright, as web applications become increasingly complex and sophisticated. Organizations are increasingly reliant on web applications to conduct business, and they need to be confident that their web applications are secure and reliable.

Here are some of the key trends that are expected to shape the future of WAT:

Increased focus on security: Security is a top priority for all organizations, and WAT is essential for identifying and mitigating security vulnerabilities. In the future, we can expect to see even more emphasis on security testing, as web applications become increasingly targeted by cyberattacks.

Rise of artificial intelligence (AI) and machine learning (ML): AI and ML are already being used in WAT, and their role is expected to grow in the future. AI and ML can be used to automate repetitive tasks, such as test case generation and execution. They can also be used to identify complex patterns and anomalies that may be difficult to detect with traditional testing methods.

Shift to cloud-based testing: More and more organizations are moving their web applications to the cloud. This trend is driving the growth of cloud-based WAT platforms. Cloud-based testing platforms offer a number of advantages, such as scalability, flexibility, and cost-effectiveness.

Increased focus on user experience (UX) testing: UX testing is essential for ensuring that web applications are easy to use and meet the needs of users. In the future, we can expect to see more focus on UX testing, as organizations increasingly recognize the importance of providing a positive user experience.

Future scope of the testing process

The future scope of the testing process is bright, as software becomes increasingly complex and sophisticated. Organisations are increasingly reliant on software to conduct business, and they need to be confident that their software is high-quality and reliable

Here are some of the key trends that are expected to shape the future of the testing process:

Increased focus on continuous testing: Continuous testing is a methodology that involves testing software throughout the SDLC, from development to deployment. This helps to identify defects early and prevent them from causing problems later in the development process.

Rise of AI and ML: AI and ML are already being used in the testing process, and their role is expected to grow in the future. AI and ML can be used to automate repetitive tasks, such as test case generation and execution. They can also be used to identify complex patterns and anomalies that may be difficult to detect with traditional testing methods.

Shift to cloud-based testing: Cloud-based testing platforms offer a number of advantages, such as scalability, flexibility, and cost-effectiveness. This is driving the growth of cloud-based testing platforms.

Increased focus on testing automation: Testing automation is the use of software to execute test cases without human intervention. Testing automation can help to save time and resources, and it can also help to improve the quality and efficiency of testing.

Future scope of SOC / SEIM: -

The future scope of Zero Trust Network Access (ZTNA) and the broader Zero Trust framework is poised for significant evolution, driven by emerging technologies and changing threat landscapes:

AI-Driven Zero Trust (AI-ZTA): Future Zero Trust implementations will leverage advanced AI and deep learning to move beyond static policies. Systems will continuously learn user behavior, predict anomalous activities before they occur, and dynamically adjust access privileges in real-time based on contextual risk, creating a truly "adaptive" security posture.

Integration with Edge Computing and IoT: As organizations deploy more IoT devices and edge computing nodes, Zero Trust principles will extend to these resource-constrained environments. Expect the development of lightweight Zero Trust agents and protocols that can authenticate and secure machine-to-machine (M2M) communication at the edge, preventing large-scale botnet attacks.

Identity-Centric Everything: The future will see identity become the ultimate security perimeter. Zero Trust will evolve to incorporate advanced identity verification methods, including continuous behavioral biometrics (keystroke dynamics, gait analysis) and decentralized identity solutions using blockchain, ensuring that the user behind the session is verified at all times.

Convergence with SASE Architecture: Zero Trust will be a core component of the Secure Access Service Edge (SASE) framework. This convergence will provide organizations with a unified, cloud-delivered stack that combines ZTNA, Secure Web Gateways (SWG), Cloud Access Security Brokers (CASB), and Firewall-as-a-Service (FWaaS), simplifying management and ensuring consistent security for all users, regardless of location

1. **Zero Trust for Operational Technology (OT) and Critical Infrastructure:** Sectors like energy, manufacturing, and healthcare will increasingly adopt Zero Trust to protect critical infrastructure. Future scope includes air gapped Zero Trust solutions and specialized protocols designed to secure legacy industrial control systems (ICS) and SCADA environments from nation-state attacks.
2. **Automated Threat Hunting and Response:** Future Zero Trust platforms will integrate with Security Orchestration, Automation, and Response (SOAR) tools to enable automated threat hunting. Upon detecting a compromised identity or device, the system will not just block access but automatically initiate investigation playbooks, isolate affected systems, and even roll back malicious changes.

Topics explored: -

Data Collection and Aggregation, Standardization and Normalisation, Enrichment and Analysis, Sharing and Distribution, Integration with Security Tools, Customization and Flexibility, Automation and Orchestration, Community Involvement, Incident Response Support, Threat Intelligence Feeds, Soc and Siem

Tools explored: -

Nmap, Metasploit, Nessus, Kali Linux, OWASP ZAP, Burp Suite

THE END